

ZEHLA ECOSYSTEM

Blueprint de Seguranca de Dados

Arquitetura completa de protecao para o ecossistema
ZEHLA / SMARTHOTEL — LGPD, Criptografia, Controle de
Acesso, Auditoria e Resposta a Incidentes

Documento tecnico de referencia para implementacao dos 7 pilares de
seguranca: conformidade LGPD, criptografia AES-256-GCM, RBAC com
MFA, protecao de sessoes WhatsApp, audit logging imutavel, backup 3-2-1
e plano de resposta a incidentes com notificacao ANPD em 72h.

CONFIDENCIAL

Versao 1.0 — Maio 2025

SMARTHOTEL Tecnologia para Hospitalidade

Table of Contents

1. Introducao: Por Que Seguranca de Dados e Critica	3
2. Framework de Conformidade LGPD	4
2.1 Bases Legais de Tratamento Aplicaveis	4
2.2 Direitos dos Titulares e Mecanismos de Exercicio	5
2.3 Documentos de Conformidade Obrigatorios	5
3. Arquitetura de Criptografia	6
3.1 Criptografia em Transito (TLS 1.3)	6
3.2 Criptografia em Repouso (AES-256-GCM)	7
4. Controle de Acesso e Autenticacao	8
4.1 Autenticacao Multi-Fator (MFA)	8
4.2 Modelo RBAC: Papeis e Permissoes	8
4.3 Row-Level Security (RLS) no PostgreSQL	9
5. Seguranca de Mensagens WhatsApp	10
5.1 Securitizacao de Sessoes WhatsApp	10
5.2 Criptografia de Conteudo de Mensagens	10
5.3 Gestao de Tokens e Credenciais de API	11
6. Protecao de Dados de Leads e Planilhas	11
6.1 Seguranca na Ingestao de Dados	12
6.2 Protecao de Planilhas Exportadas	12
6.3 Anonimizacao e Eliminacao de Dados	12
7. Logging de Auditoria e Monitoramento	13
7.1 Eventos de Auditoria Obrigatorios	13
7.2 Arquitetura do Sistema de Logs	14
8. Backup e Recuperacao de Desastres	15
8.1 Estrategia de Backup PostgreSQL	15

8.2 Backup de Sessoes e Dados em Redis	15
9. Plano de Resposta a Incidentes de Seguranca	16
9.1 Classificacao de Incidentes	16
9.2 Fluxo de Resposta a Incidentes	17
10. Seguranca de Infraestrutura	18
10.1 Hardening de Servidor	18
10.2 Protecao contra Ataques Comuns	18
11. Integracao com o Pipeline ZEHLA Brain (Fase 4)	19
11.1 Tipos de Evento de Seguranca no Pipeline	19
11.2 Dashboard de Seguranca Unificado	20
12. Roadmap de Implementacao por Prioridade	20
12.1 Metricas de Verificacao e KPIs de Seguranca	21

1. Introducao: Por Que Seguranca de Dados e Critica

O ecossistema ZEHLA opera na intersecao de tres vetores de alta sensibilidade: dados pessoais de proprietarios de pousadas coletados de fontes publicas, mensagens enviadas e recebidas via WhatsApp que trafegam informacoes comerciais confidenciais, e dados comportamentais gerados pelo sistema de pontuacao e classificacao de leads. A combinacao desses elementos cria um superficie de ataque significativa que exige uma arquitetura de seguranca robusta, multi-camadas e em conformidade com a legislacao brasileira de protecao de dados.

Com mais de 10.000 contatos de pousadas em sua base de dados, incluindo numeros de telefone, nomes, localizacoes geograficas e perfis de negocio, qualquer violacao de seguranca pode resultar em danos reputacionais irreparaveis, multas regulatórias severas pela Autoridade Nacional de Protecao de Dados (ANPD), e a perda de confianca dos proprietarios que constituem o nucleo do modelo de negocio SMARTHOTEL. Alem disso, as mensagens enviadas via WhatsApp carregam propostas comerciais, precos e estrategias que, se expostas, podem comprometer vantagens competitivas significativas no mercado de hospitalidade.

Este blueprint define a arquitetura de seguranca completa para o ecossistema ZEHLA, cobrindo sete pilares fundamentais: (1) conformidade com a LGPD e framework de privacidade, (2) criptografia de dados em repouso e em transito, (3) controle de acesso e autenticacao multi-fator, (4) seguranca especifica para mensagens WhatsApp, (5) protecao de dados de leads e planilhas sensíveis, (6) logging de auditoria e monitoramento em tempo real, e (7) plano de resposta a incidentes e recuperacao de desastres. Cada pilar e detalhado com controles tecnicos especificos, prioridades de implementacao e metricas de verificacao.

Categoria	Exemplos	Nivel de Risco	Regulamentacao
Dados Pessoais	Nome, telefone, e-mail, endereco da pousada, CNPJ	ALTO	LGPD Art. 5, Art. 46
Mensagens WhatsApp	Propostas comerciais, respostas de leads, historico de conversas	CRITICO	LGPD Art. 7, Marco Civil

Dados Comportamentais	Score de lead, estagio do funil, cluster, historico de interacoes	MEDIO-ALTO	LGPD Art. 8, Art. 20
Dados de Negocio	Estrategia de precos, taxas de conversao, taxa de resposta	ALTO	Segredo empresarial
Credenciais de Acesso	Tokens API, chaves de criptografia, sessoes WhatsApp	CRITICO	LGPD Art. 46, LGPD Art. 48

Tabela 1: Classificacao de dados sensíveis do ecossistema ZEHLA

2. Framework de Conformidade LGPD

A Lei Geral de Protecao de Dados (Lei 13.709/2018) estabelece regras claras sobre coleta, armazenamento, tratamento e compartilhamento de dados pessoais no Brasil. O ecossistema ZEHLA, ao operar com dados de proprietarios de pousadas captados de fontes publicas como Google Maps e redes sociais, precisa garantir que todas as bases legais de tratamento sejam respeitadas. A lgica central é que, mesmo quando os dados são publicos, o seu tratamento para fins comerciais exige bases legais especificas, como legítimo interesse ou consentimento, dependendo do contexto e da finalidade.

2.1 Bases Legais de Tratamento Aplicaveis

Para cada tipo de operacao de dados realizada pelo ZEHLA, é necessario identificar a base legal adequada. A tabela a seguir mapeia cada operacao do sistema para sua respectiva base legal na LGPD, incluindo o fundamento juridico e as medidas de mitigacao associadas. Este mapeamento deve ser revisado trimestralmente pelo DPO (Data Protection Officer) designado e atualizado sempre que novas funcionalidades forem adicionadas ao sistema.

Operacao	Base Legal	Artigo LGPD	Medida Necessaria
Captura de leads de fontes publicas	Legitimo Interesse	Art. 7, IX	Teste de proporcionalidade e ROPA
Envio de mensagens WhatsApp	Consentimento	Art. 7, I	Opt-in confirmado, opt-out facil
Scoring e classificacao de leads	Execucao de contrato	Art. 7, V	Transparencia no processamento

Armazenamento de mensagens	Obrigacao legal	Art. 7, II	Retention policy definida
Compartilhamento com SMARTHOTEL	Consentimento	Art. 7, I	DPA assinado entre partes

Tabela 2: Mapeamento de operacoes para bases legais LGPD

2.2 Direitos dos Titulares e Mecanismos de Exercicio

A LGPD garante aos titulares de dados uma serie de direitos que devem ser implementados como funcionalidades técnicas no sistema ZEHLA. O direito de acesso (Art. 18) exige que qualquer proprietario de pousada possa solicitar e receber, em ate 15 dias, uma copia completa de todos os dados pessoais armazenados. O direito de eliminacao (Art. 18, VI) requer que o sistema suporte a exclusao completa de um lead e todas as suas interacoes associadas, incluindo mensagens, scores e eventos do pipeline, mantendo apenas registros anonimizados para fins estatisticos quando aplicavel.

O direito de portabilidade (Art. 18, V) implica que o ZEHLA deve ser capaz de exportar todos os dados de um titular em formato estruturado e de uso corrente, como JSON ou CSV. Ja o direito de revogacao do consentimento (Art. 8, par. 5) exige que, ao receber uma solicitacao de opt-out, o sistema interrompa imediatamente qualquer envio de mensagens ao numero revogado e marque o lead como inativo no pipeline de eventos. A implementacao desses direitos como rotinas automatizadas no backend do ZEHLA Brain garante conformidade operacional e reduz o risco de penalidades da ANPD.

2.3 Documentos de Conformidade Obrigatorios

Para demonstrar conformidade com a LGPD, o ecossistema ZEHLA precisa manter uma suite de documentos de governanca de dados. O Registro de Operacoes de Tratamento (ROPA) e o documento central que mapeia todas as atividades de processamento de dados, incluindo categorias de titulares, dados tratados, finalidades, bases legais, medidas de seguranca e prazo de retencao. Este registro deve ser atualizado sempre que houver alteracoes nas operacoes de tratamento e deve estar disponivel para consulta pela ANPD mediante solicitacao.

Alem do ROPA, o ZEHLA necessita de um Termo de Privacidade especifico para proprietarios de pousadas que recebem mensagens, um Relatorio de Impacto a Protecao de Dados (RIPD) que avalie os riscos do processamento em massa de

dados pessoais via WhatsApp, e uma Política de Retenção que defina prazos claros para cada categoria de dado. Os prazos recomendados são: mensagens WhatsApp (90 dias após última interação), dados de scoring (12 meses), leads inativos sem resposta (6 meses), e registros de auditoria (24 meses). Após expiração do prazo, os dados devem ser anonimizados ou eliminados de forma segura.

3. Arquitetura de Criptografia

A criptografia é o pilar técnico mais fundamental da estratégia de segurança do ZEHILA. Sem criptografia adequada, qualquer vulnerabilidade no perímetro de segurança pode resultar na exposição em texto claro de dados pessoais, mensagens comerciais e credenciais de acesso. A arquitetura de criptografia do ZEHILA é dividida em três camadas complementares: criptografia em trânsito para proteger dados que se movem entre componentes do sistema, criptografia em repouso para proteger dados armazenados em banco de dados e filesystems, e criptografia em uso para proteger dados enquanto são processados pela aplicação.

3.1 Criptografia em Trânsito (TLS 1.3)

Todas as comunicações entre componentes do ecossistema ZEHILA devem utilizar TLS 1.3 como protocolo mínimo de criptografia. Isso inclui a comunicação entre o frontend Next.js e a API backend, entre o backend e o PostgreSQL, entre o backend e o Redis, entre workers BullMQ e o broker Redis, e entre o backend e os serviços externos como API WhatsApp (Evolution API, Z-API) e serviços de e-mail. A configuração do Nginx ou do load balancer deve desabilitar explicitamente TLS 1.0, TLS 1.1 e TLS 1.2, mantendo apenas TLS 1.3 com cipher suites modernos como TLS_AES_256_GCM_SHA384.

Para a conexão com o PostgreSQL, é necessário configurar o parâmetro `sslmode=require` no Prisma connection string e gerar certificados SSL autoassinados com validade de 1 ano para o cluster de banco de dados. A conexão Redis também deve utilizar TLS via stunnel ou Redislabs com suporte nativo a TLS. No nível da aplicação Next.js, todas as rotas API devem habilitar o header Strict-Transport-Security (HSTS) com valor `max-age=31536000; includeSubDomains; preload`, forçando o navegador a utilizar HTTPS exclusivamente.

Implementação prática no Prisma schema para PostgreSQL com SSL:

```
DATABASE_URL="postgresql://user:pass@host:5432/zehila?sslmode=require&sslrootcert;=/etc/ssl/certs/pg-ca.pem"
```

3.2 Criptografia em Repouso (AES-256-GCM)

Dados em repouso no PostgreSQL e no filesystem devem ser protegidos com criptografia AES-256-GCM. No banco de dados, campos sensíveis como números de telefone, endereços de e-mail, conteúdo de mensagens e tokens de sessão WhatsApp devem ser criptografados na camada da aplicação antes da persistência, utilizando uma estratégia de envelope encryption. Cada registro recebe uma chave de dados (DEK) única gerada por AES-256-GCM, e a DEK é criptografada com uma chave mestra de criptografia (KEK) armazenada em um serviço de gerenciamento de chaves (KMS).

A chave mestra (KEK) nunca deve ser armazenada no banco de dados ou no código-fonte. Ela deve residir exclusivamente em variáveis de ambiente protegidas ou em um serviço de KMS como AWS KMS, HashiCorp Vault ou, para deployments on-premise, em um hardware security module (HSM) ou arquivo criptografado acessível somente pelo processo da aplicação. O uso de envelope encryption garante que, mesmo que um atacante obtenha acesso ao banco de dados, ele não consiga descriptografar os campos sensíveis sem acessar a KEK.

Para PostgreSQL, é recomendado adicionalmente habilitar o recurso pgcrypto e TDE (Transparent Data Encryption) no nível do cluster. Para volumes de disco (em deployments VPS ou bare-metal), utilizar LUKS (Linux Unified Key Setup) para criptografia full-disk, garantindo que dados no disco não sejam legíveis em caso de roubo físico do hardware ou acesso não autorizado ao storage.

Campo de Dado	Algoritmo	Chave	Rotacao
Telefone do lead	AES-256-GCM	DEK por registro	90 dias
Conteúdo mensagem	AES-256-GCM	DEK por mensagem	90 dias
Token sessão WhatsApp	AES-256-GCM + HMAC	KEK global	30 dias
API keys (Z-API)	AES-256-GCM	KEK global	A cada rotação de key
Planilhas de leads	AES-256-GCM (ficheiro)	DEK por arquivo	A cada upload

Tabela 3: Matriz de criptografia por campo de dado

4. Controle de Acesso e Autenticacao

O controle de acesso no ecossistema ZEHLA segue o principio do menor privilegio (PoLP) e o modelo RBAC (Role-Based Access Control). Cada usuario do sistema, seja administrador, operador de vendas, ou membro da equipe de suporte, possui um conjunto minimo de permissoes necessarias para executar suas funcoes. A implementacao desses controles deve ser realizada tanto na camada de API (middleware de autenticacao) quanto na camada de banco de dados (row-level security do PostgreSQL), garantindo defesa em profundidade.

4.1 Autenticacao Multi-Fator (MFA)

Todos os acessos ao painel administrativo do ZEHLA devem obrigatoriamente utilizar autenticacao multi-fator. A arquitetura recomendada combina tres fatores: algo que voce sabe (senha com minimo de 12 caracteres, incluindo maiusculas, minusculas, numeros e simbolos especiais), algo que voce tem (TOTP via Google Authenticator ou Authy), e algo que voce e (opcional, para acoes criticas como exportacao de dados em massa ou alteracao de permissoes de usuarios). A implementacao deve utilizar a biblioteca otp do Node.js para geracao e validacao de codigos TOTP, com secrets armazenados no banco de dados criptografados via AES-256.

Sessoes de usuario devem ter tempo de expiracao curto: 15 minutos para o painel administrativo, 30 minutos para a API de operacoes, e 1 hora para dashboards de visualizacao. Cada sessao deve receber um refresh token com validade de 7 dias, armazenado como cookie HttpOnly, Secure e SameSite=Strict. O backend deve implementar validacao de device fingerprint, detectando logins simultaneos em dispositivos diferentes e forçando reautenticacao automaticamente quando uma anomalia e detectada. Tentativas falhas de login devem ser limitadas a 5 tentativas por IP por 15 minutos, com bloqueio progressivo: 5 falhas = 5 min bloqueio, 10 falhas = 30 min bloqueio, 15 falhas = 24h bloqueio.

4.2 Modelo RBAC: Papeis e Permissoes

O modelo de roles do ZEHLA define quatro papeis principais com permissoes granulares. O papel Admin possui acesso total ao sistema, incluindo gerenciamento de usuarios, configuracoes de seguranca e exportacao de dados. O papel Operator pode enviar mensagens, visualizar leads e acessar dashboards, mas nao pode alterar configuracoes do sistema. O papel Analyst possui acesso somente leitura a dashboards e relatorios, sem capacidade de modificar dados. Finalmente, o papel API_Service e utilizado por servicos automatizados e

workers, com acesso limitado as APIs necessarias para a execucao de tarefas programadas.

Permissao	Admin	Operator	Analyst	API Service
Visualizar leads	SIM	SIM	SIM	SIM
Enviar mensagens	SIM	SIM	NAO	SIM
Exportar dados	SIM	NAO	SIM	NAO
Gerenciar usuarios	SIM	NAO	NAO	NAO
Configurar seguranca	SIM	NAO	NAO	NAO
Acessar logs auditoria	SIM	NAO	SIM	NAO
Deletar leads	SIM	NAO	NAO	NAO
Alterar scores	SIM	SIM	NAO	SIM

Tabela 4: Matriz de permissoes RBAC do ecossistema ZEHLA

4.3 Row-Level Security (RLS) no PostgreSQL

Alem do controle de acesso na aplicacao, o PostgreSQL deve implementar Row-Level Security para garantir que, mesmo que um atacante consiga acessar o banco de dados diretamente, ele so consiga visualizar os dados permitidos pelo seu papel. A configuracao do RLS no ZEHLA deve criar policies que filtrem leads por regio do operador, mensagens por sessao WhatsApp autorizada, e eventos do pipeline por tenant. A habilitacao do RLS e feita com o comando `ALTER TABLE ... ENABLE ROW LEVEL SECURITY`, seguido pela criacao de policies especificas para cada tabela e papel.

Para a tabela de leads, a policy de RLS deve garantir que operadores so visualizem leads da sua regio atribuida (definida por um campo `region_id` no schema), enquanto admins visualizam todos os leads. Para a tabela de mensagens, a policy deve restringir o acesso a mensagens associadas a sessoes WhatsApp ativas do usuario logado. Para a tabela de eventos do pipeline (implementada na Fase 4), a policy deve garantir que a API de webhook so consiga criar eventos (INSERT) mas nunca ler ou modificar eventos existentes.

5. Seguranca de Mensagens WhatsApp

O envio de mensagens em massa via WhatsApp representa o vetor de risco mais complexo do ecossistema ZEHLA. As mensagens trafegam informacoes comerciais confidenciais (propostas, precos, condicoes), dados pessoais dos leads (nomes, telefones, preferencias) e conteudo de marketing que, se exposto ou interceptado, pode comprometer toda a operacao comercial. Alem disso, o uso de APIs de terceiros (Evolution API, Z-API) introduz dependencias de seguranca que precisam ser gerenciadas com rigor.

5.1 Securitizacao de Sessoes WhatsApp

As sessoes WhatsApp (tokens de autenticacao, cookies e dados de conexao) devem ser tratadas como credenciais de altissima sensibilidade, equivalentes a chaves privadas de criptografia. Cada sessao deve ser armazenada no Redis com criptografia AES-256-GCM e tempo de expiracao (TTL) de 24 horas, forçando a renovacao periodica. O storage de sessoes no Redis garante que, em caso de comprometimento do PostgreSQL, as sessoes WhatsApp continuem protegidas em um sistema de cache isolado com politicas de eviccao proprias.

A renovacao de sessoes deve ser automatizada via um worker BullMQ que verifica a validade de cada sessao a cada 6 horas e dispara o processo de reconexao antes da expiracao. O worker deve logar cada renovacao com timestamp, ID da sessao e status, permitindo auditoria completa do ciclo de vida das sessoes. Em caso de falha na renovacao, o sistema deve notificar o administrador via e-mail e Telegram, e interromper qualquer envio de mensagens pela sessao afetada ate que a conexao seja restabelecida.

5.2 Criptografia de Conteudo de Mensagens

O conteudo das mensagens enviadas e recebidas via WhatsApp deve ser criptografado antes da persistencia no banco de dados. Isso inclui tanto o texto da mensagem quanto os metadados (timestamp, status de entrega, ID da mensagem no WhatsApp). A criptografia deve ser aplicada na camada de servico do backend, antes de chamar o Prisma para persistir os dados. O campo de conteudo criptografado no banco de dados deve ser armazenado como texto base64, contendo o IV (Initialization Vector) concatenado ao ciphertext.

A implementacao pratica utiliza o modulo nativo crypto do Node.js com o algoritmo aes-256-gcm. Cada mensagem recebe um IV aleatorio de 12 bytes gerado por crypto.randomBytes(), e o resultado da criptografia inclui o authentication tag de 16 bytes que garante a integridade do ciphertext. A chave de criptografia das mensagens (MEK - Message Encryption Key) e derivada da

KEK mestra via HKDF (HMAC-based Key Derivation Function), garantindo que a comprometicão de uma chave de mensagem não comprometa as demais.

Implementação de referência para criptografia de mensagens no backend:

```
import crypto from "crypto";
const ALGO = "aes-256-gcm";
const IV_LEN = 12; const TAG_LEN = 16;
function encryptMessage(plaintext: string, key: Buffer) {
  const iv = crypto.randomBytes(IV_LEN);
  const cipher = crypto.createCipheriv(ALGO, key, iv);
  let enc = cipher.update(plaintext, "utf8", "base64");
  enc += cipher.final("base64");
  const tag = cipher.getAuthTag();
  return iv.toString("base64") + ":" + tag.toString("base64") + ":" + enc;
}
```

5.3 Gestão de Tokens e Credenciais de API

As credenciais de API utilizadas para conectar o ZEHLA aos serviços de WhatsApp (Evolution API, Z-API, Baileys) devem ser gerenciadas com o mesmo nível de segurança que chaves de produção. Os tokens devem ser armazenados em variáveis de ambiente criptografadas via Docker Secrets ou AWS Secrets Manager, nunca hardcoded no código-fonte ou em arquivos de configuração commitados no repositório Git. Cada instância da API deve receber um token dedicado, permitindo revogação individual sem afetar outras conexões.

A rotação de tokens deve ocorrer a cada 90 dias, com notificação automática 7 dias antes da expiração. O processo de rotação deve ser automatizado: o sistema gera um novo token, testa a conexão, substitui o token antigo e invalida o anterior, tudo sem interrupção do serviço. Logs de rotação de tokens devem ser armazenados com nível de sensibilidade CRÍTICO e retidos por 24 meses. Qualquer tentativa de uso de token expirado deve ser logada como evento de segurança e disparar um alerta imediato ao administrador.

6. Proteção de Dados de Leads e Planilhas

A base de leads do ZEHLA, composta por mais de 10.000 contatos de pousadas captados de fontes públicas, representa o ativo de dados mais valioso e mais exposto do ecossistema. A proteção desses dados requer controles em múltiplas camadas, desde a ingestão inicial até a eliminação segura após o período de retenção. Planilhas de leads (CSV, XLSX) exportadas do sistema devem ser tratadas como documentos confidenciais com rastreamento de acesso e marca d'água digital para identificar vazamentos.

6.1 Seguranca na Ingestao de Dados

O processo de ingestao de leads no ZEHLA passa por tres etapas de validacao e sanitizacao. A primeira etapa e a validacao de schema, que verifica se cada campo do lead corresponde ao formato esperado (telefone com regex E.164, e-mail com validacao RFC 5322, coordenadas geograficas com bounding box do Brasil). A segunda etapa e a sanitizacao de dados, que remove caracteres maliciosos, normaliza formatacoes (remocao de mascaras de telefone, normalizacao de UF para sigla padrao) e aplica hashing para deduplicacao baseada em fingerprint do lead.

A terceira etapa e a classificacao de sensibilidade, que atribui automaticamente um nivel de risco a cada lead baseado nos campos preenchidos. Leads com telefone, e-mail e endereco completo recebem classificacao ALTA e tem seus campos sensíveis criptografados imediatamente. Leads com apenas nome e telefone recebem classificacao MEDIA e tem apenas o telefone criptografado. Essa classificacao triagem de risco automatizada garante que recursos de criptografia sejam aplicados onde sao mais necessarios, otimizando performance do sistema sem comprometer seguranca.

6.2 Protecao de Planilhas Exportadas

Quando leads sao exportados do sistema para planilhas (CSV, XLSX), medidas adicionais de seguranca devem ser aplicadas. Cada arquivo exportado deve receber uma marca d'agua digital invisível contendo o ID do usuario que fez a exportacao, timestamp da operacao e um hash unico do arquivo. Em caso de vazamento, essa marca d'agua permite rastrear a origem do leak. A implementacao da marca d'agua pode ser feita via metadados do arquivo XLSX (propriedades personalizadas no OpenXML) ou via steganografia em CSV (insercao de caracteres invisíveis em campos especificos).

Exportacoes em massa (mais de 1.000 leads) devem requerer aprovacao de um Admin e ser registradas no log de auditoria com nivel de detalhamento completo: usuario, IP, horario, filtros aplicados, numero de registros, e hash do arquivo gerado. Os arquivos exportados devem ter validade de acesso limitada: links de download devem expirar em 24 horas e os arquivos no servidor devem ser deletados automaticamente apos 48 horas. Para planilhas XLSX, e recomendavel aplicar protecao de senha no nivel do arquivo utilizando a biblioteca exceljs com criptografia AES-128.

6.3 Anonimizacao e Eliminacao de Dados

A LGPD exige que dados pessoais sejam eliminados quando não houver mais finalidade para seu tratamento. O ZEHLA implementa um sistema de anonimização em três níveis. O nível 1 (pseudonimização) substitui identificadores diretos por tokens reversíveis, permitindo reidentificação apenas por administradores com autorização especial. O nível 2 (anonimização irreversível) aplica técnicas de k-anonimidade e l-diversidade para garantir que leads anonimizados não possam ser reidentificados por inferência. O nível 3 (eliminação segura) aplica sobreescrita criptográfica múltipla antes da deleção definitiva, garantindo recuperação impossível mesmo com forensic tools.

7. Logging de Auditoria e Monitoramento

O logging de auditoria é o mecanismo que permite rastrear todas as ações realizadas no ecossistema ZEHLA, identificar violações de segurança, e comprovar conformidade com a LGPD em caso de auditoria pela ANPD. O sistema de logging deve seguir o princípio da imutabilidade: uma vez que um log é registrado, ele não pode ser alterado ou deletado por nenhum usuário, incluindo administradores. A imutabilidade dos logs é garantida pela utilização de uma tabela PostgreSQL com permissão somente de INSERT, sem UPDATE ou DELETE.

7.1 Eventos de Auditoria Obrigatórios

Todos os eventos de segurança do ZEHLA devem ser classificados em quatro níveis de criticidade: INFO (ações operacionais normais), WARN (ações suspeitas que não configuram violação), ALERT (eventos que indicam tentativa de violação), e CRITICAL (violação confirmada com impacto em dados). Cada evento de auditoria deve conter obrigatoriamente: timestamp em UTC com precisão de milissegundos, ID do usuário que executou a ação, IP de origem, user-agent, recurso acessado, ação realizada (CRUD), resultado (sucesso/falha), e dados adicionais contextuais em formato JSON.

Evento	Nível	Retenção	Alerta
Login bem-sucedido	INFO	90 dias	NAO
Login falhado (5+ tentativas)	ALERT	24 meses	SIM
Exportação de leads em massa	WARN	24 meses	SIM
Alteração de permissões de usuário	ALERT	24 meses	SIM

Envio de mensagem WhatsApp	INFO	90 dias	NAO
Acesso a dados criptografados	WARN	12 meses	SIM
Rotacao de chave de criptografia	ALERT	24 meses	SIM
Tentativa de SQL injection	CRITICAL	Indefinida	SIM
Acesso nao autorizado a API	CRITICAL	Indefinida	SIM
Exclusao de lead (LGPD)	ALERT	Indefinida	SIM

Tabela 5: Eventos de auditoria obrigatórios com níveis de criticidade

7.2 Arquitetura do Sistema de Logs

O sistema de logging do ZEHLA utiliza uma arquitetura de tres camadas. A primeira camada e o Application Logger, implementado via Winston ou Pino no backend Next.js, que captura todos os eventos da aplicacao com formatacao estruturada em JSON. A segunda camada e o Audit Database, uma tabela PostgreSQL dedicada (audit_logs) com particionamento mensal por data e indexacao por user_id, resource e severity. A terceira camada e o SIEM (Security Information and Event Management), opcional para deployments de producao, que agrega logs de todas as camadas (aplicacao, banco, Nginx, Redis) em um unico painel de analise.

Para alertas em tempo real, o ZEHLA deve implementar um sistema de notificacao baseado no pipeline de eventos ja existente (Fase 4 Brain Sync). Eventos de nivel ALERT e CRITICAL disparam acoes automaticas: ALERT gera notificacao via e-mail para o administrador e registro no dashboard de seguranca; CRITICAL gera notificacao via Telegram, e-mail e interrompe a operacao afetada ate revisao manual. A integracao com o pipeline de eventos ja implementado permite reaproveitar toda a infraestrutura de scoring, classificacao e acao automatica do ZEHLA Brain para eventos de seguranca.

8. Backup e Recuperacao de Desastres

O plano de backup e recuperacao de desastres do ZEHLA e projetado para garantir a continuidade do negocio em caso de falhas de hardware, ataques de ransomware, erros humanos ou desastres naturais. A estrategia segue a regra 3-2-1: tres copias dos dados, em dois tipos de midia diferentes, com uma copia offsite. O objetivo de recuperacao (RPO - Recovery Point Objective) e de no maximo 1 hora para dados criticos (leads, mensagens) e 24 horas para dados de analytics. O objetivo de tempo de recuperacao (RTO - Recovery Time Objective) e de no maximo 4 horas para restauracao completa do sistema.

8.1 Estrategia de Backup PostgreSQL

O PostgreSQL utiliza uma estrategia de backup combinando full dumps semanais com WAL (Write-Ahead Log) archiving continuo. O full dump e executado toda noite as 02:00 UTC via `pg_dump` com formato custom e compressao lz4, armazenando o resultado em um bucket S3 com versionamento habilitado e criptografia AES-256 server-side. Os arquivos de WAL sao arquivados continuamente a cada 5 minutos para o mesmo bucket S3, permitindo restauracao point-in-time com granularidade de 5 minutos. O backup da chave de criptografia (KEK) e armazenado separadamente em um cofre fisico ou em um servico KMS diferente do S3.

A verificacao de integridade dos backups e realizada automaticamente a cada 24 horas via `pg_verifybackup`, que valida que o arquivo de backup pode ser restaurado com sucesso. Alem disso, um teste de restauracao completo e executado mensalmente em um ambiente de staging isolado, simulando um cenario de recuperacao de desastre real. Os resultados de cada verificacao e teste sao registrados no log de auditoria com detalhes como tamanho do backup, tempo de verificacao, status e eventuais erros encontrados.

8.2 Backup de Sessoes e Dados em Redis

O Redis, utilizado para cache de sessoes WhatsApp e filas BullMQ, implementa persistencia combinada RDB + AOF. O RDB (snapshot) e gerado a cada 15 minutos para um arquivo local, e o AOF (append-only file) registra cada operacao de escrita em tempo real. Esses arquivos sao copiados para o bucket S3 a cada hora. Em caso de falha do Redis, a recuperacao prioritaria restaura o AOF mais recente, seguido do RDB como fallback. Sessoes WhatsApp perdidas sao recriadas automaticamente pelo worker de renovacao de sessoes.

Componente	Frequencia	Destino	RPO	Retencao
PostgreSQL Full	Diario (02:00 UTC)	S3 + local	24h	30 dias
PostgreSQL WAL	Continuo (5 min)	S3	5 min	7 dias
Redis RDB	A cada 15 min	S3	15 min	3 dias
Redis AOF	Continuo	S3 (horario)	1h	3 dias
Chaves de Criptografia	A cada rotacao	KMS / cofre	0 (simultaneo)	Indefinida
Logs de Auditoria	Continuo	PostgreSQL + S3	0 (real-time)	24 meses

Tabela 6: Estrategia de backup por componente do ecossistema

9. Plano de Resposta a Incidentes de Seguranca

O plano de resposta a incidentes define procedimentos claros para identificar, conter, erradicar e recuperar-se de violacoes de seguranca no ecossistema ZEHLA. Este plano e fundamental para cumprir o Art. 48 da LGPD, que exige que a Autoridade Nacional de Protecao de Dados (ANPD) seja notificada em ate 72 horas apos a percepcao de um incidente de seguranca que possa acarretar risco ou dano relevante aos titulares de dados. A comunicacao aos titulares afetados tambem e obrigatoria quando o incidente puder resultar em risco significativo para seus direitos e liberdades.

9.1 Classificacao de Incidentes

Os incidentes de seguranca do ZEHLA sao classificados em quatro niveis de severidade, cada um com procedimentos de resposta especificos e prazos de notificacao definidos. O nivel P1 (Critico) inclui exposicao de dados pessoais em massa, comprometimento da chave mestra de criptografia, ransomware no servidor de producao, ou acesso nao autorizado ao banco de dados. Incidentes P1 requerem resposta imediata (15 minutos), notificacao a ANPD em 72 horas e comunicacao aos titulares afetados em 72 horas.

O nível P2 (Alto) abrange acessos não autorizados a contas de usuário, exfiltração parcial de dados, ou comprometimento de sessões WhatsApp. Incidentes P2 requerem resposta em 1 hora, avaliação de risco para determinação de notificação a ANPD, e comunicação interna imediata. O nível P3 (Medio) inclui tentativas de ataque bloqueadas com sucesso, vulnerabilidades descobertas mas não exploradas, e configurações incorretas de segurança. O nível P4 (Baixo) cobre eventos de segurança informativos que não representam risco imediato, como scans de porta bloqueados ou logins falhados com poucas tentativas.

Nível	Exemplos	Tempo de Resposta	Notificação ANPD	Comunicação Titulares
P1 - Crítico	Exposição de dados em massa, ransomware, comprometimento KEK	15 minutos	72 horas	72 horas
P2 - Alto	Acesso não autorizado a conta, exfiltração parcial	1 hora	Apos avaliação	Se risco significativo
P3 - Medio	Tentativas bloqueadas, vulnerabilidades não exploradas	4 horas	Registro interno	NAO
P4 - Baixo	Scans bloqueados, logins falhados isolados	24 horas	NAO	NAO

Tabela 7: Classificação de incidentes e procedimentos de notificação

9.2 Fluxo de Resposta a Incidentes

O fluxo de resposta a incidentes segue a metodologia NIST (National Institute of Standards and Technology) adaptada ao contexto do ecossistema ZEHLA. A fase de Preparação inclui a manutenção da lista de contatos de emergência (equipe de segurança, jurídico, comunicação, ANPD), a realização de simulados trimestrais de resposta a incidentes, e a atualização periódica do plano. A fase de Detecção e Análise utiliza o sistema de logging de auditoria e alertas em tempo real para identificar anomalias, com análise de causa raiz para determinar o escopo e impacto do incidente.

A fase de Contenção isola imediatamente os sistemas afetados: revogação de sessões WhatsApp comprometidas, bloqueio de contas de usuário suspeitas, e

isolamento de servidores infectados. A fase de Erradicacao remove a causa raiz do incidente, aplicando patches, revogando credenciais comprometidas e corrigindo vulnerabilidades. A fase de Recuperacao restaura os sistemas a operacao normal utilizando os backups validados, com monitoramento intensivo nos 7 dias seguintes. A fase de Pos-incidente gera um relatorio detalhado das condições aprendidas e ações corretivas, atualizando o plano de segurança conforme necessário.

10. Segurança de Infraestrutura

A segurança da infraestrutura física e de rede do ZEHILA constitui a primeira linha de defesa contra ataques externos. Mesmo que todos os controles de aplicação e dados estejam implementados corretamente, uma configuração incorreta no servidor, no firewall ou no DNS pode abrir vetores de ataque que contornam todas as camadas de segurança superiores. A arquitetura de infraestrutura do ZEHILA deve seguir o modelo de defesa em profundidade, com múltiplas barreiras de segurança em cada camada.

10.1 Hardening de Servidor

O servidor de produção do ZEHILA deve seguir um checklist de hardening que inclui: desabilitar portas e serviços desnecessários (somente SSH na porta 2222, HTTP/HTTPS na 80/443), configurar fail2ban para bloqueio automático de IPs com tentativas de brute force, desabilitar login root via SSH e utilizar autenticação por chave SSH exclusivamente (senha desabilitada), configurar UFW (Uncomplicated Firewall) com regras default DROP para INPUT e FORWARD, e permitir apenas tráfego nas portas necessárias.

Além disso, o sistema operacional deve receber atualizações de segurança automáticas via unattended-upgrades (configurado para security-only), com reboot automático programado caso necessário. Os processos da aplicação devem rodar sob usuários dedicados com privilégios mínimos (nunca como root), e o Docker deve ser configurado com security-opt=no-new-privileges:true e read-only filesystem para os containers que não precisam de escrita. O acesso SSH ao servidor deve ser restrito a IPs whitelistados e autenticação por chave pública com passphrase.

10.2 Proteção contra Ataques Comuns

O ZEHILA deve implementar proteções específicas contra os vetores de ataque mais comuns em aplicações web. Para proteção contra SQL Injection, todas as queries ao banco de dados devem utilizar Prisma Client com parameterized

queries (nunca template strings com concatenacao de inputs). Para protecao contra XSS (Cross-Site Scripting), o Next.js deve utilizar o `componentnext/head` com `Content-Security-Policy` header restritivo, e todos os inputs de usuario devem ser sanitizados com `DOMPurify` antes da renderizacao. Para protecao contra CSRF (Cross-Site Request Forgery), todas as rotas de API que modificam estado devem validar o token CSRF gerado pelo Next.js middleware.

Para protecao contra Rate Limiting, o Nginx (ou o middleware do Next.js) deve limitar requisicoes a 100 req/min por IP para rotas de API e 10 req/min para rotas de autenticao. Para protecao contra brute force em logins, a politica de bloqueio progressivo descrita na secao de autenticao deve ser implementada. Headers de seguranca obrigatorios devem incluir `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, e `Permissions-Policy` para restringir acesso a APIs do navegador como camera, microfone e geolocation.

11. Integracao com o Pipeline ZEHLA Brain (Fase 4)

A arquitetura de seguranca nao opera de forma isolada: ela se integra profundamente com o pipeline de eventos implementado na Fase 4 do ZEHLA Brain. O sistema de eventos (Capture, Validate, Enrich, Classify, Act) que ja rastreia interacoes de leads e calcula scores deve ser estendido para capturar e classificar eventos de seguranca, criando uma visao unificada de todas as atividades do ecossistema.

11.1 Tipos de Evento de Seguranca no Pipeline

O sistema de tipos de evento existente no ZEHLA Brain (`types.ts`) deve ser estendido com tres novas categorias dedicadas a seguranca: `SECURITY_AUTH` para eventos de autenticao (login, logout, falha de MFA), `SECURITY_DATA` para eventos de protecao de dados (exportacao, criptografia, rotacao de chaves), e `SECURITY_INFRA` para eventos de infraestrutura (firewall, patch, backup). Cada tipo de evento de seguranca possui seu proprio impacto no score de risco do sistema, permitindo que o ZEHLA Brain detecte padroes anormais de atividade e dispare alertas automaticos.

A integracao pratica e feita estendendo o enum `EventType` em `types.ts` com os novos tipos de seguranca, atualizando o validator para aceitar payloads de evento de seguranca, e adicionando regras no `scoring.ts` para calcular um "

Security Score" que reflete o nível de risco atual do sistema. Quando o SecurityScore ultrapassa um limiar crítico (definido por variável de ambiente), o pipeline de ações dispara automaticamente o lockdown parcial do sistema: sessões WhatsApp são pausadas, exports são bloqueados, e o administrador recebe notificação imediata via todos os canais configurados.

11.2 Dashboard de Segurança Unificado

O dashboard de eventos existente em /events deve ser estendido com um widget de segurança que exibe em tempo real o Security Score do sistema, a lista de alertas ativos, o mapa de calor de tentativas de acesso suspeitas por região geográfica (reaproveitando o componente LeafletMap já implementado no LIS), e o histórico de incidentes com sua resolução. Este dashboard unificado permite ao operador visualizar tanto a saúde comercial do funil de vendas quanto a saúde de segurança do sistema em uma única interface, sem necessidade de alternar entre ferramentas.

12. Roadmap de Implementação por Prioridade

A implementação da arquitetura de segurança deve seguir uma abordagem incremental, priorizando os controles que mitigam os maiores riscos primeiro. O roadmap a seguir define quatro fases de implementação, cada uma com entregáveis concretos e métricas de verificação. A priorização foi baseada na análise de risco das superfícies de ataque do ecossistema ZEHLA, considerando a probabilidade e o impacto de cada ameaça identificada.

Fase	Prazo	Entregáveis	Prioridade
Fase 1: Fundamentos	Semanas 1-2	TLS 1.3 em todas as conexões, MFA para admin, env vars para segredos, headers de segurança, rate limiting	CRÍTICA
Fase 2: Criptografia	Semanas 3-4	Envelope encryption para campos sensíveis, criptografia de mensagens, KEK em KMS, rotação automática	ALTA
Fase 3: Auditoria	Semanas 5-6	Tabela audit_logs imutável, eventos de segurança no pipeline Brain, alertas em tempo real, dashboard de segurança	ALTA

Fase 4: LGPD	Semanas 7-8	ROPA, RIPD, politica de retencao, endpoints de direitos do titular, opt-out automatico, anonimizacao	ALTA
Fase 5: Infraestrutura	Semanas 9-10	Hardening de servidor, fail2ban, UFW, backup automatizado com verificacao, plano de resposta a incidentes	MEDIA
Fase 6: Avancado	Semanas 11-12	RLS no PostgreSQL, marca d'agua em exports, SIEM integracao, simulados trimestrais, HSM para KEK	MEDIA

Tabela 8: Roadmap de implementacao da arquitetura de seguranca

12.1 Metricas de Verificacao e KPIs de Seguranca

Cada fase de implementacao deve ser validada por metricas claras que demonstrem a eficacia dos controles implementados. Para a Fase 1 (Fundamentos), as metricas incluem: 100% das conexoes utilizam TLS 1.3 (verificavel via SSL Labs scan), 100% dos logins admin utilizam MFA (verificavel via log de auditoria), e zero credenciais hardcoded no repositorio Git (verificavel via git-secrets ou truffleHog). Para a Fase 2 (Criptografia), as metricas incluem: 100% dos campos sensíveis criptografados no banco de dados (verificavel via query de rotina), rotacao de chaves executada com sucesso nos prazos definidos, e tempo de criptografia/descriptografia inferior a 5ms por operacao (performance).

Para as fases subsequentes, as metricas evoluem para cobrir cobertura de logs de auditoria (100% dos eventos obrigatorios registrados), tempo de deteccao de incidentes (MTTD inferior a 15 minutos para eventos CRITICAL), tempo de resposta a incidentes (MTTR inferior a 4 horas para P1), e conformidade LGPD (documentos de governanca completos e atualizados). Essas metricas devem ser monitoradas em um dashboard de seguranca dedicado e revisadas mensalmente pela equipe com reuniao de retrospectiva de seguranca.